LAB-01 — Actividad 1: Clasificación de datos

Campo	¿Identifica directamente?	¿Puede contribuir a identificar?	¿Requiere protección?	Justificación
ID	No	Si	Si	Permite relacionar registros con un cliente.
Nombre	Si	Si	Si	Puede identificar a una persona.
Correo	Si	Si	Si	Puede revelar la identidad del cliente.
Telefono	Si	Si	Si	Puede utilizarse para identificar o contactar a una persona.
rfc	Si	Si	Si	Es un identificador fiscal.
Edad	No	Si	Si	Puede ayudar a identificar a alguien.
Ciudad	No	Si	Si	Proporciona información de ubicación.
Codigo_postal	No	Si	Si	Permite identificar una zona geográfica.
Fecha_alta	No	Si	Si	Puede relacionarse con otros datos.

1. **¿Qué campos identifican directamente a una persona?**

Los campos que pueden identificar directamente a una persona son el nombre, correo electrónico, teléfono y RFC, ya que contienen información relacionada con su identidad. El ID también permite identificar a un cliente dentro del sistema cuando se relaciona con sus datos.

2. **¿Qué campos no identifican por sí solos, pero podrían contribuir a hacerlo?**

La edad, ciudad, código postal y fecha de alta. Aunque por separado no suelen identificar directamente a alguien, al combinarse pueden proporcionar información suficiente para reconocer a una persona.

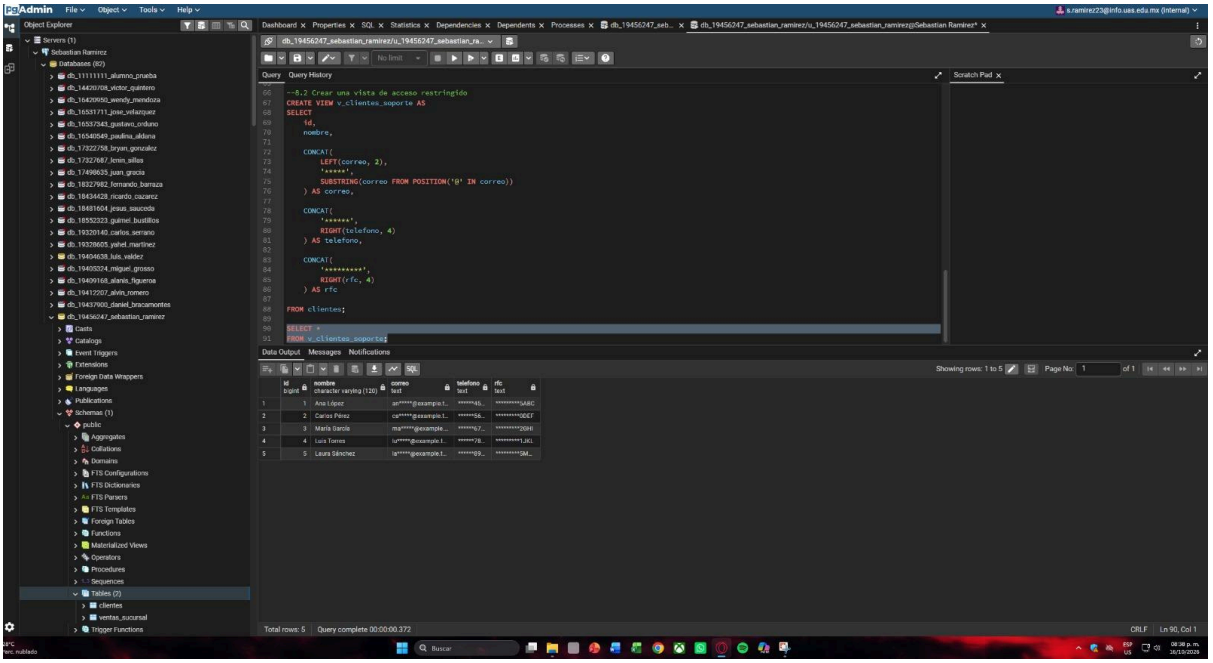
3. **¿Qué combinación de campos podría incrementar el riesgo de reidentificación?**

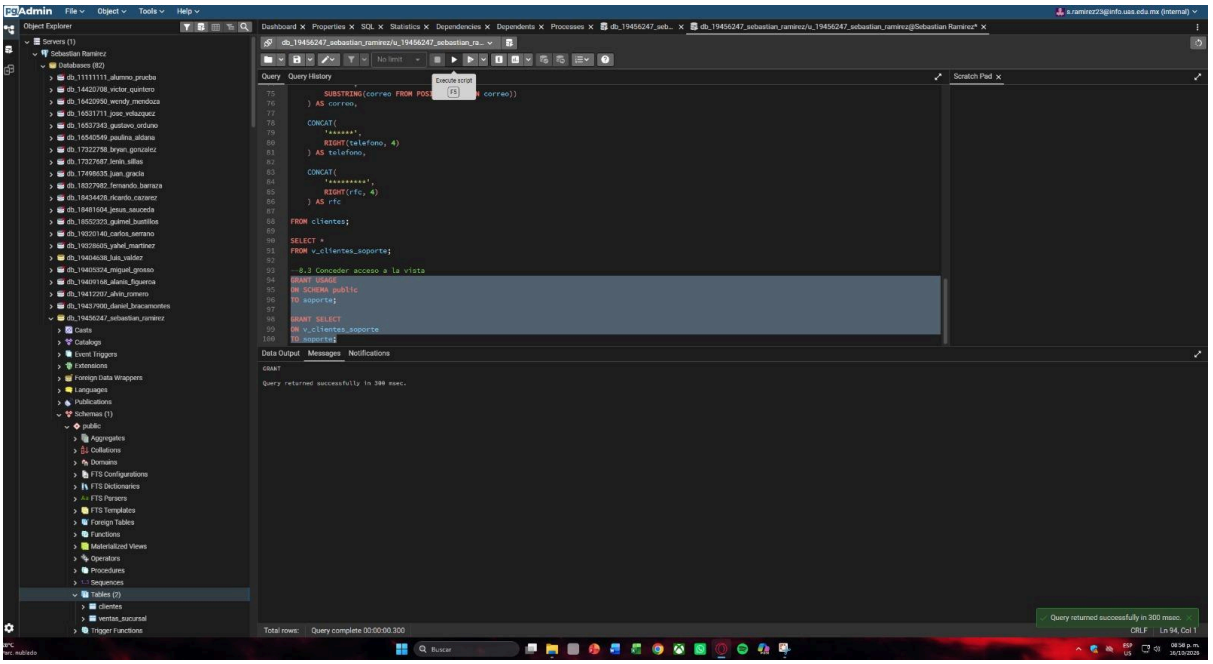
Una combinación de edad, ciudad y código postal podría aumentar el riesgo de reidentificación, especialmente si existen pocos clientes con esas características. También se podría utilizar la fecha de alta para reducir aún más las posibilidades.

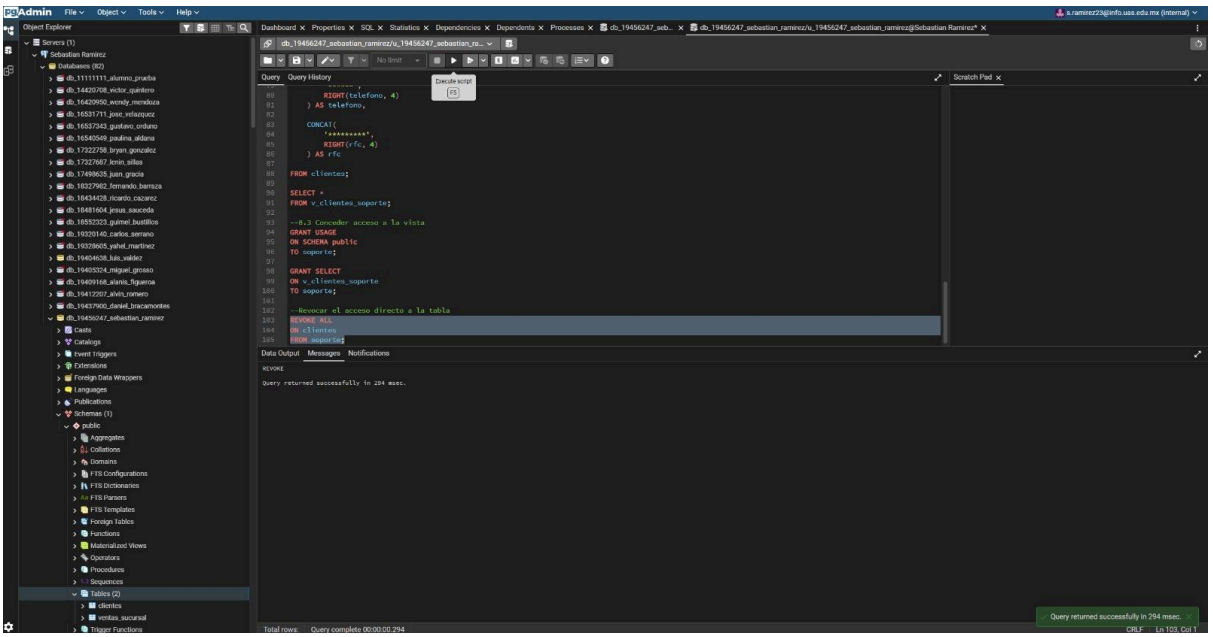
4. **¿Todos los datos que deben protegerse son necesariamente datos personales sensibles desde el punto de vista jurídico?**

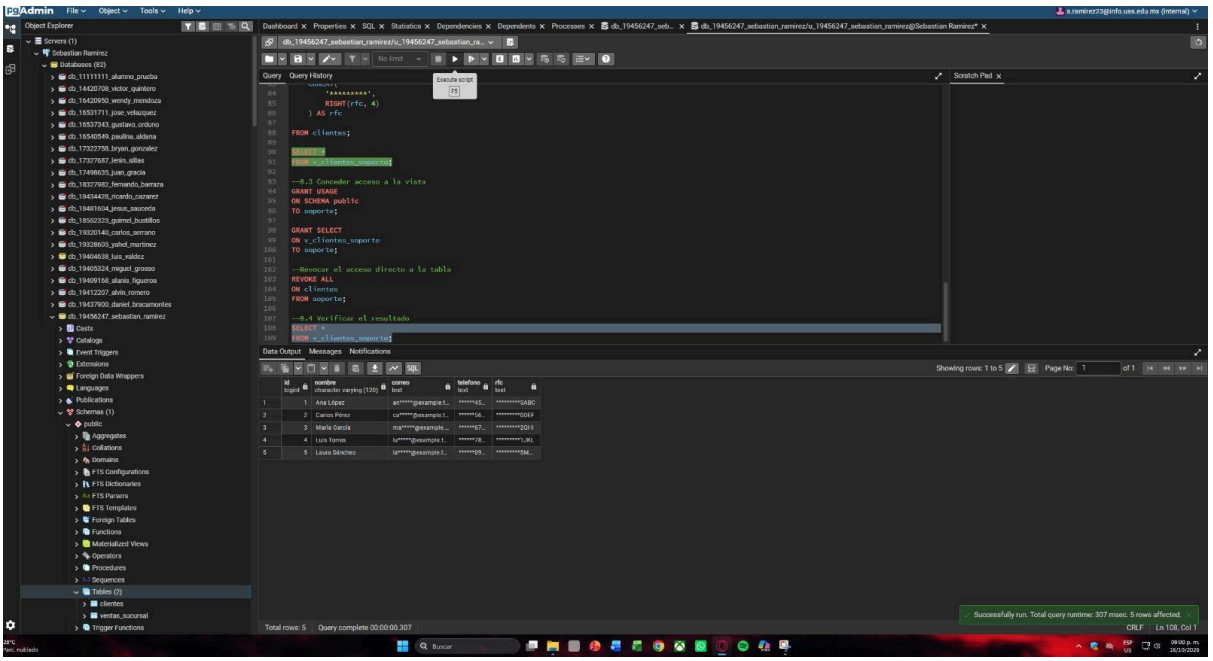
No, porque existen datos personales que necesitan protección aunque no sean considerados sensibles legalmente. Por ejemplo, el nombre y el correo electrónico son datos personales, pero no necesariamente sensibles. Aun así, deben protegerse para evitar que personas no autorizadas accedan a ellos.

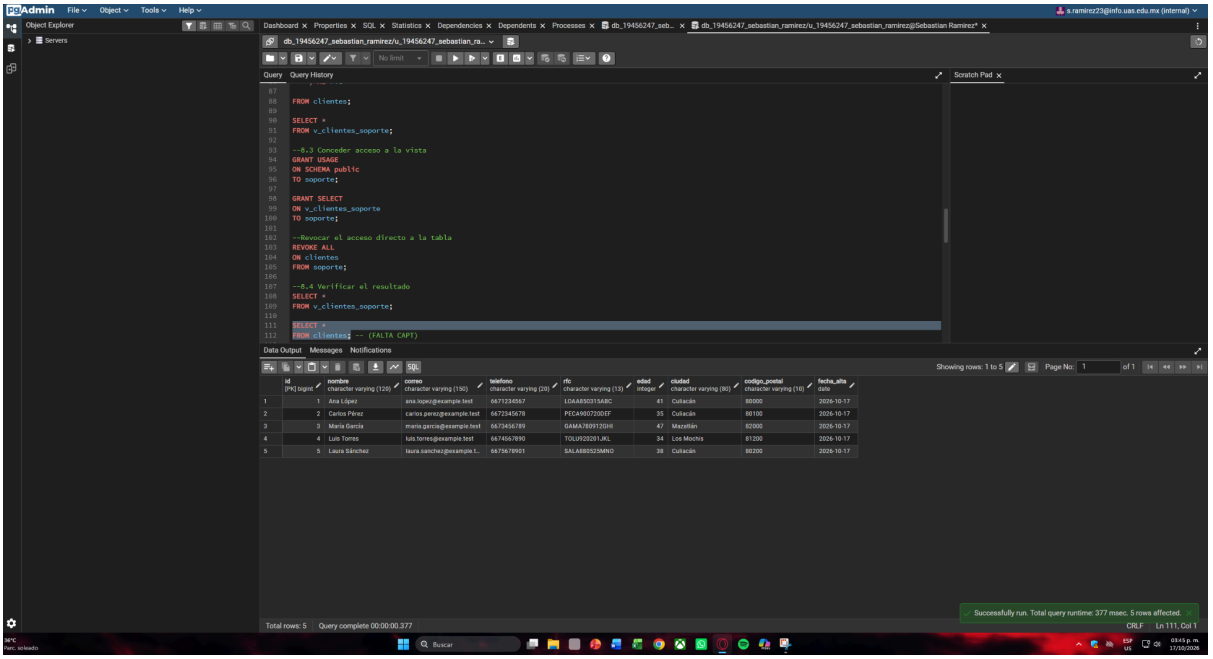
Actividad 2 — Enmascaramiento (Masking)






PgAdmin
Object Explorer
Dashboard
Properties
SQL
Statistics
Dependencies
Dependents
Processes
Query
Query History
Scratch Pad
Data Output
Messages
Notifications
REVOKE
Query returned successfully in 204 msec.
Query returned successfully in 294 msec.
Total rows:
Query complete 00:00:00.294
CRLF
Ln 103, Col 1


PgAdmin
Object Explorer
Dashboard
Properties
SQL
Statistics
Dependencies
Dependents
Processes
Query
Query History
Scratch Pad
Data Output
Messages
Notifications
Showing rows: 1 to 5
Page No: 1
of 1
Successfully run. Total query runtime: 307 msec. 5 rows affected.
Total rows: 5
Query complete 00:00:00.307
CRLF
Ln 108, Col 1



Aclaración:

Al realizar la consulta SELECT * FROM clientes, me dejaba visualizar los datos, aunque el acceso debía estar restringido para el rol soporte.

El resultado esperado era que el rol soporte pudiera consultar únicamente la vista v_clientes_soporte, donde el correo, teléfono y RFC aparecen parcialmente ocultos. Al intentar consultar directamente la tabla clientes, debía aparecer un mensaje de acceso denegado.

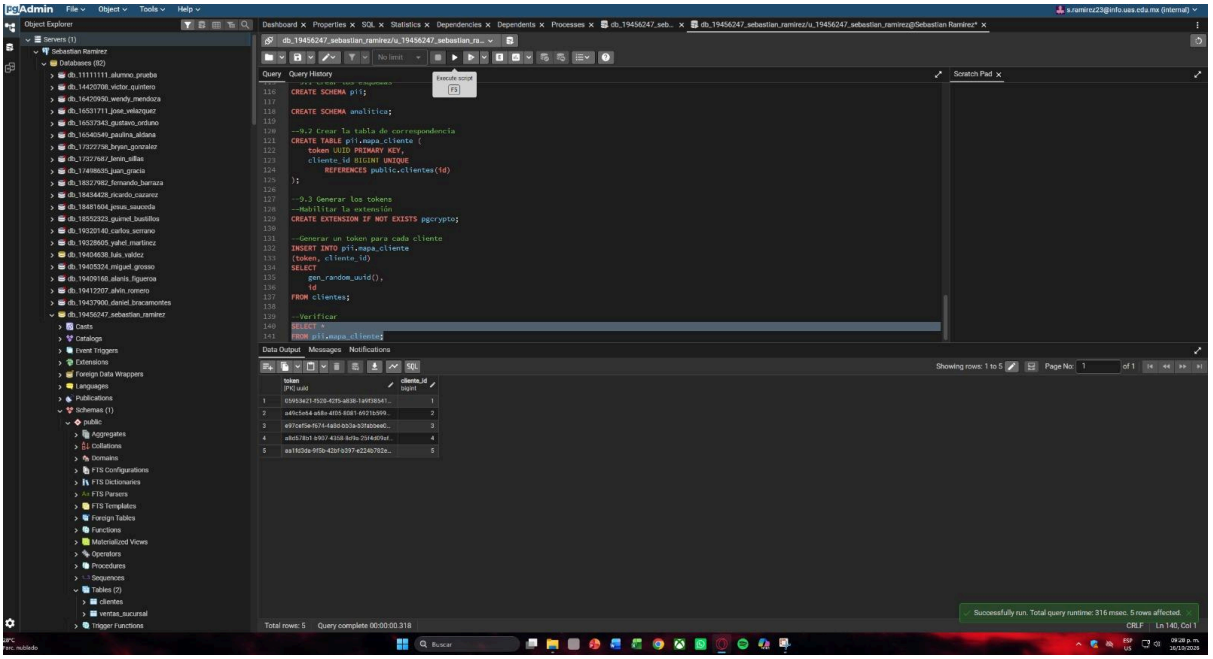
1. ¿Qué información continúa existiendo en la tabla original? Respondimos que todos los datos originales siguen almacenados y que el enmascaramiento solamente oculta parte de ellos en la vista.

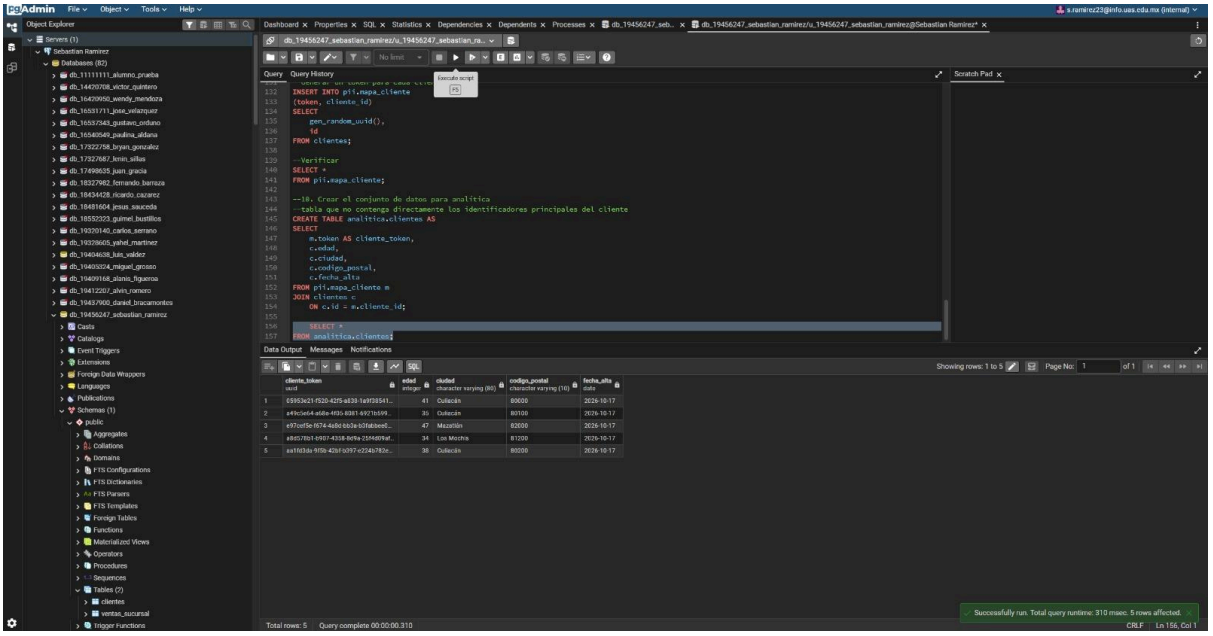
2. ¿Qué información puede visualizar el usuario soporte? El ID, nombre, correo, teléfono y RFC parcialmente enmascarados.

3. ¿Por qué no es suficiente ocultar los datos únicamente en la aplicación? Porque alguien con acceso directo a la base de datos podría consultar la información completa si no existen restricciones.

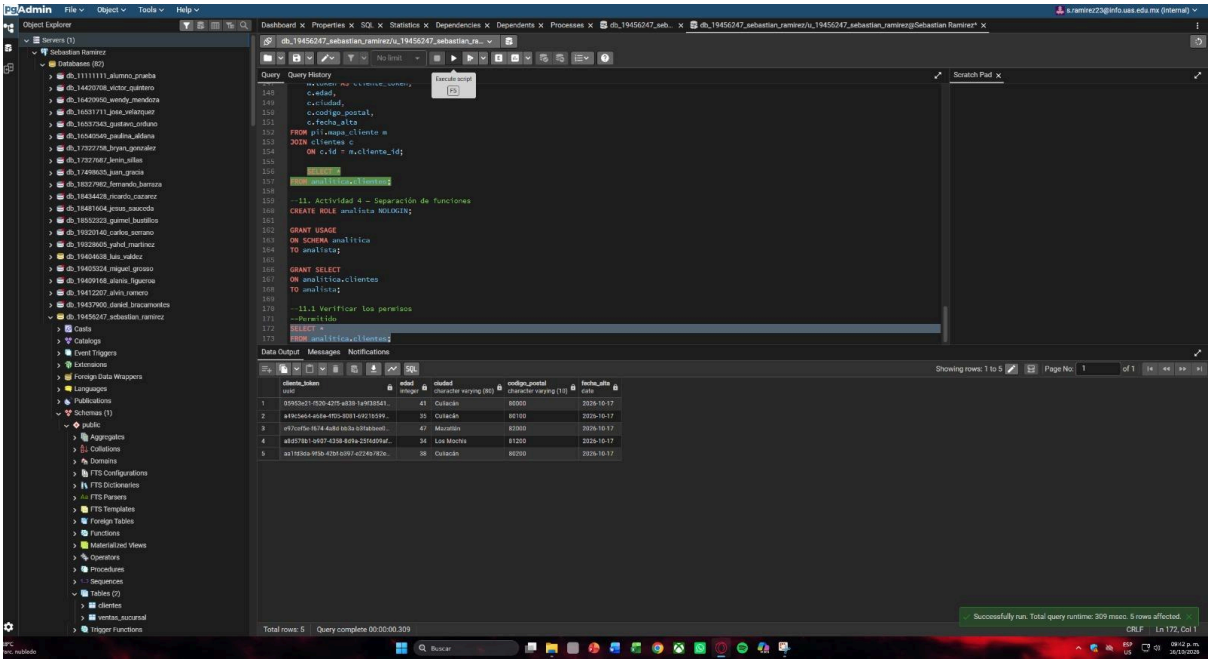
4. ¿Qué ocurriría si soporte tuviera acceso directo a clientes? Podría visualizar información personal que no necesita, aumentando el riesgo de exposición de datos.

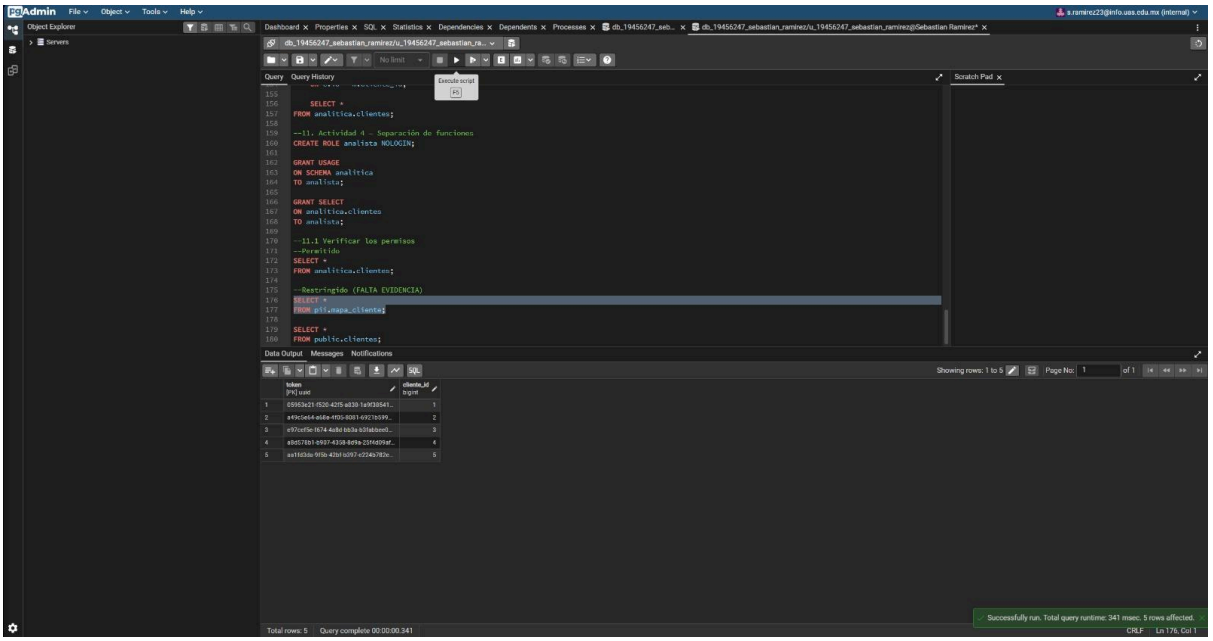
Actividad 3 — Seudonimización

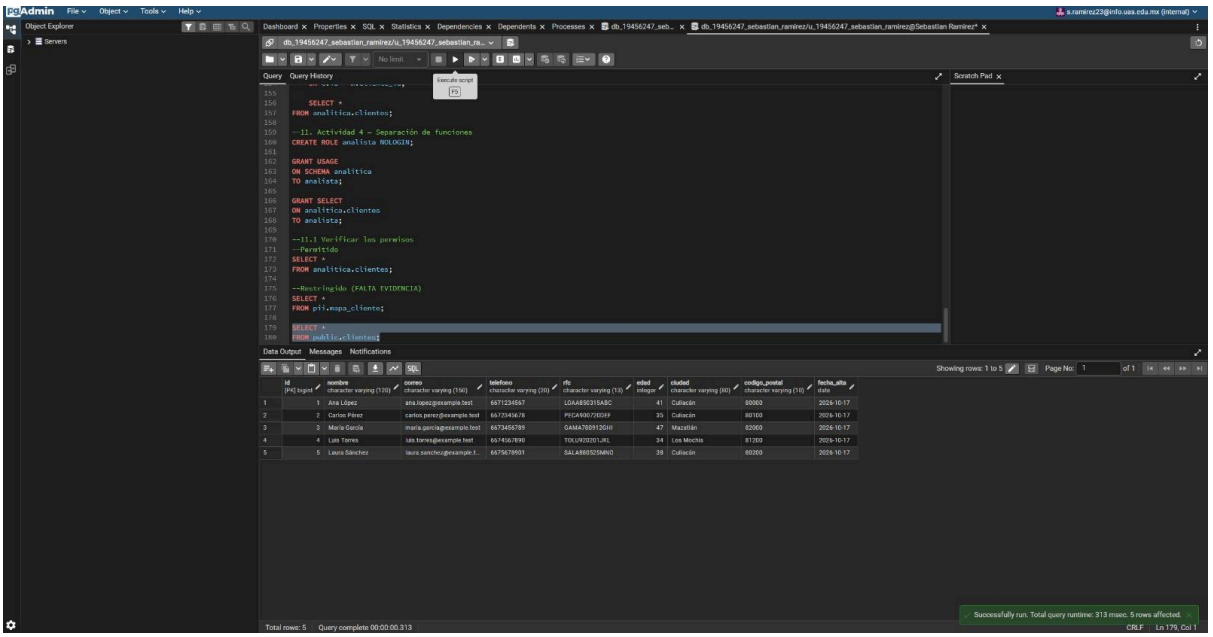




Actividad 4 — Separación de funciones







Aqui me paso algo similar, me era posible visualizar la información de las tablas pii.mapa_clientes y public.clientes, aunque estas deberían estar restringidas para el rol analista.

El resultado esperado era que el rol analista pudiera consultar únicamente la tabla analitica.clientes, mientras que al intentar acceder a las otras dos tablas apareciera un mensaje de error por falta de permisos.

1. ¿Qué ocurriría si analista pudiera consultar también pii.mapa_cliente?

Si el analista tuviera acceso a esa tabla, podría relacionar los tokens con los ID originales de los clientes. Esto aumentaría el riesgo de identificar a las personas, especialmente si también pudiera consultar la tabla original.

2. ¿Qué principio de seguridad se está aplicando al separar ambos accesos?

Se está aplicando el principio de mínimo privilegio y la separación de funciones. Esto significa que cada usuario solamente debe tener acceso a la información que necesita para realizar su trabajo, evitando que pueda consultar datos confidenciales sin autorización.

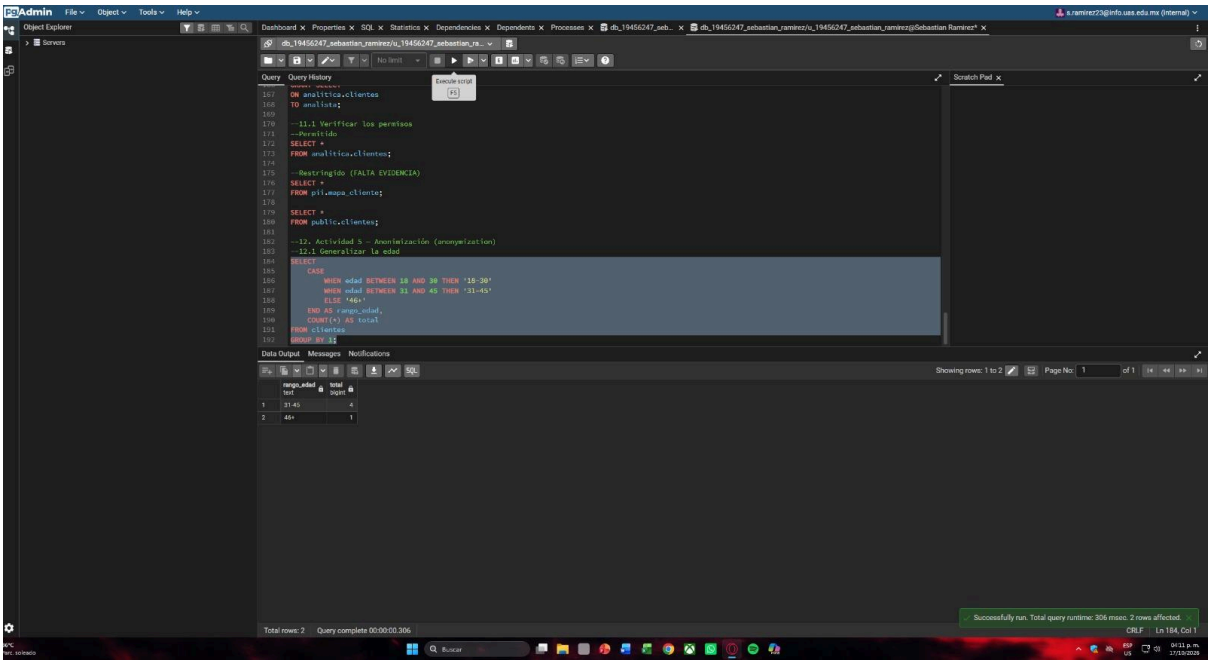
3. ¿Por qué la seudonimización no equivale a anonimización?

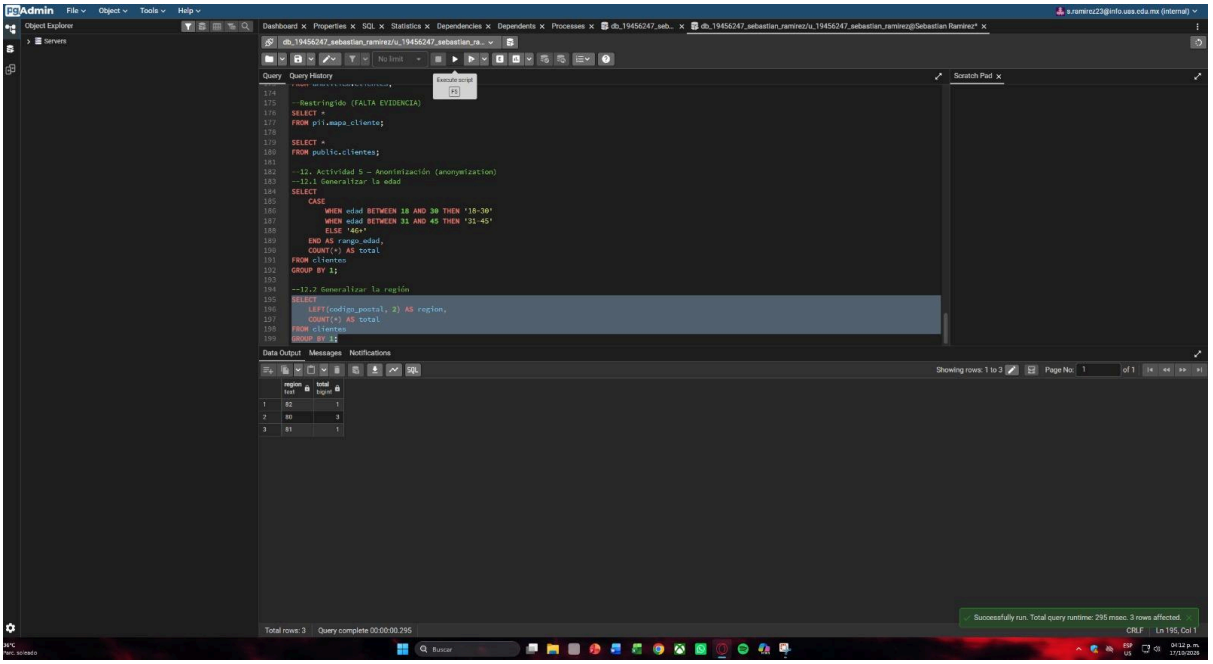
Porque la seudonimización reemplaza los identificadores originales por tokens, pero todavía existe una tabla que permite relacionarlos con las personas. En cambio, la anonimización busca que no sea razonablemente posible identificar nuevamente a una persona.

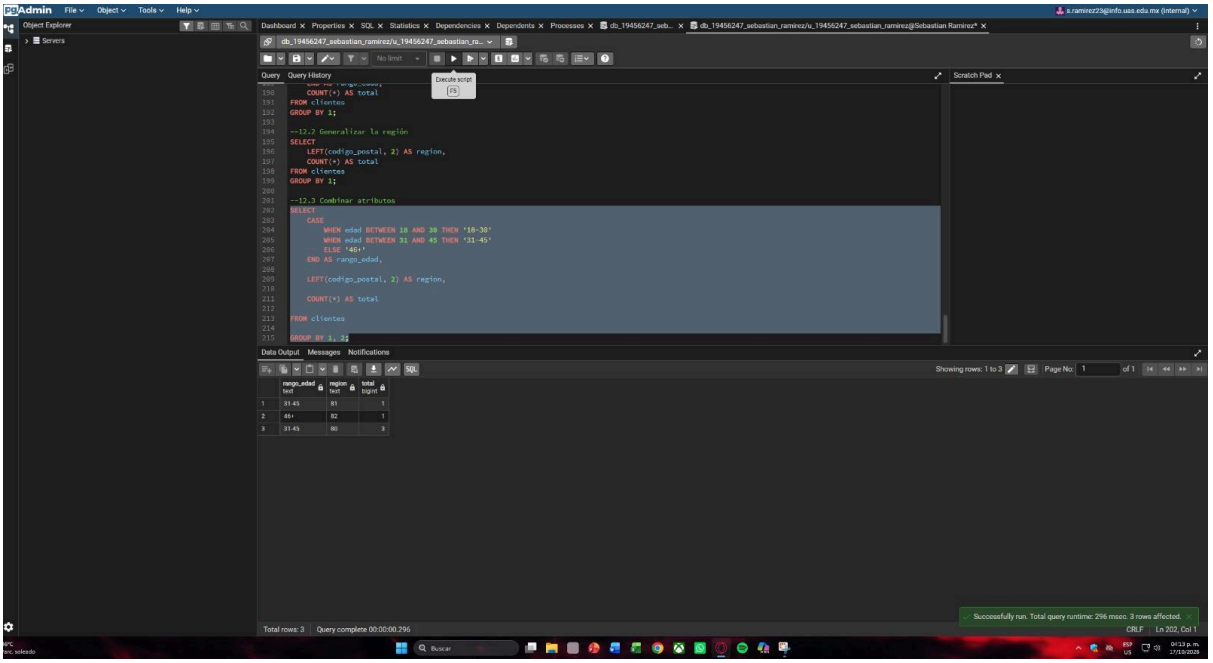
4. ¿Qué información permite volver a relacionar el token con una persona?

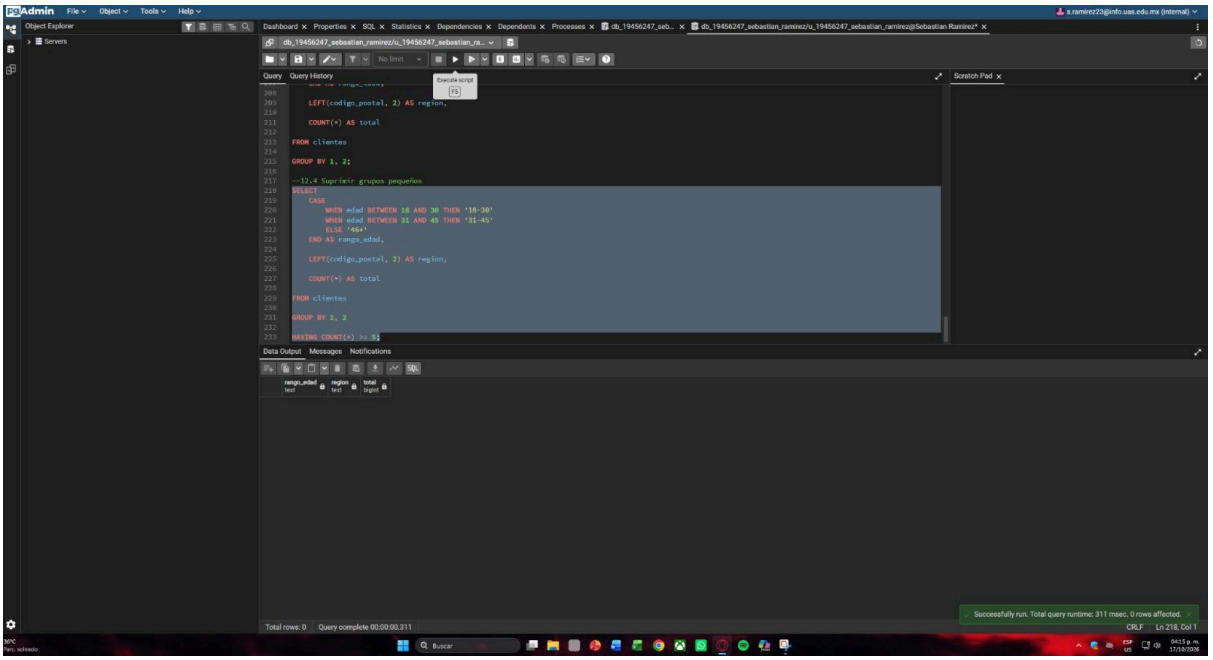
La tabla pii.mapa_clientes, ya que almacena la relación entre cada token y el ID original del cliente. Con esa información y acceso a la tabla public.clientes, se puede identificar a qué persona pertenece cada token.

Actividad 5 — Anonimización (Anonymization)









Actividad 6 — Análisis del riesgo de reidentificación

1. ¿Qué identificadores directos fueron eliminados?

En los resultados de las consultas se omitieron datos como el nombre, correo electrónico, teléfono, RFC y el ID original del cliente. Esto permite analizar información sin mostrar directamente la identidad de las personas. Sin embargo, esos datos siguen existiendo en la tabla original.

2. ¿Qué cuasi-identificadores permanecen?

Permanecen el rango de edad y la región obtenida del código postal. Aunque estos datos no identifican directamente a una persona, podrían ayudar a reconocerla si se combinan con otra información.

3. ¿Qué combinaciones de atributos podrían reducir el anonimato?

La combinación del rango de edad con la región puede aumentar el riesgo de identificar a una persona, especialmente cuando existen pocos clientes con esas características.

4. ¿Qué sucede cuando un grupo contiene pocos registros?

Cuando un grupo tiene pocos registros, es más fácil identificar a las personas que pertenecen a él. Por eso utilizamos HAVING COUNT(*) >= 5, para evitar mostrar grupos con menos de cinco clientes.

5. ¿Qué atributos deberían generalizarse?

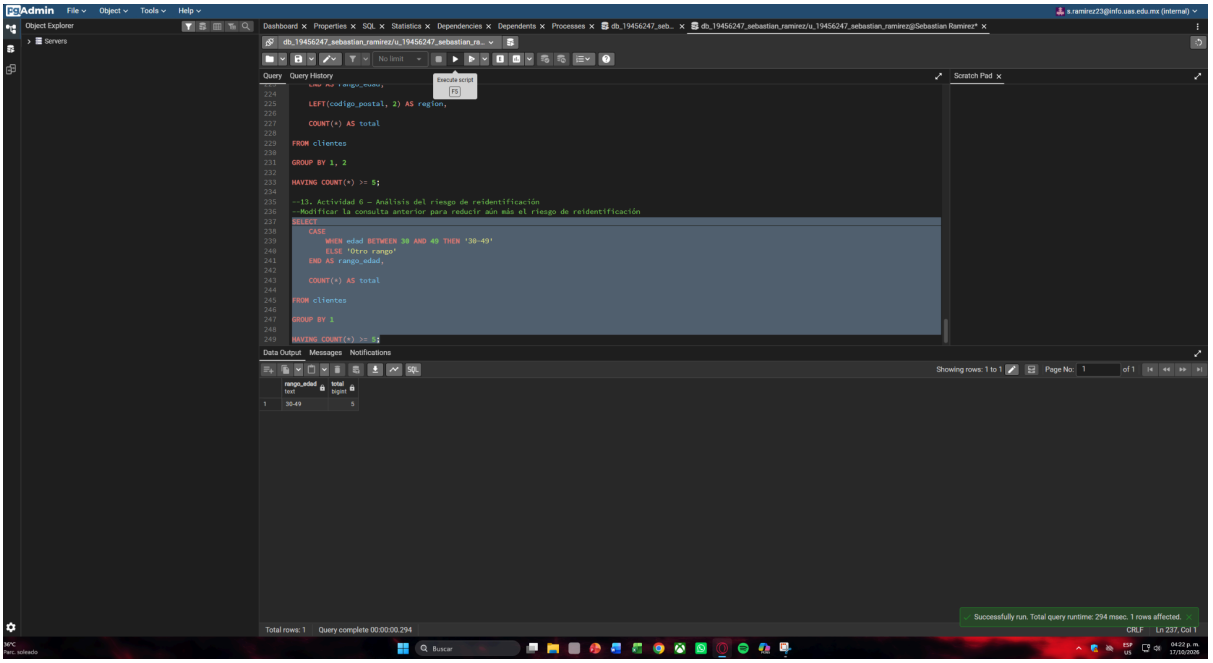
Principalmente la edad y el código postal. Podemos utilizar rangos de edad más amplios y regiones geográficas menos específicas para reducir el nivel de detalle de la información.

6. ¿Qué información debería suprimirse?

Se deberían ocultar los identificadores directos, como nombres, correos, teléfonos y RFC. También se podrían suprimir grupos con pocos registros o atributos demasiado específicos que aumenten el riesgo de identificación.

7. ¿Es correcto afirmar que el conjunto de datos es "100 % anónimo"? ¿Por qué?

No, porque aunque eliminemos los identificadores directos y agrupemos la información, todavía podría existir la posibilidad de identificar a una persona combinando los datos con otras fuentes. Estas técnicas reducen el riesgo, pero no garantizan un anonimato completo.



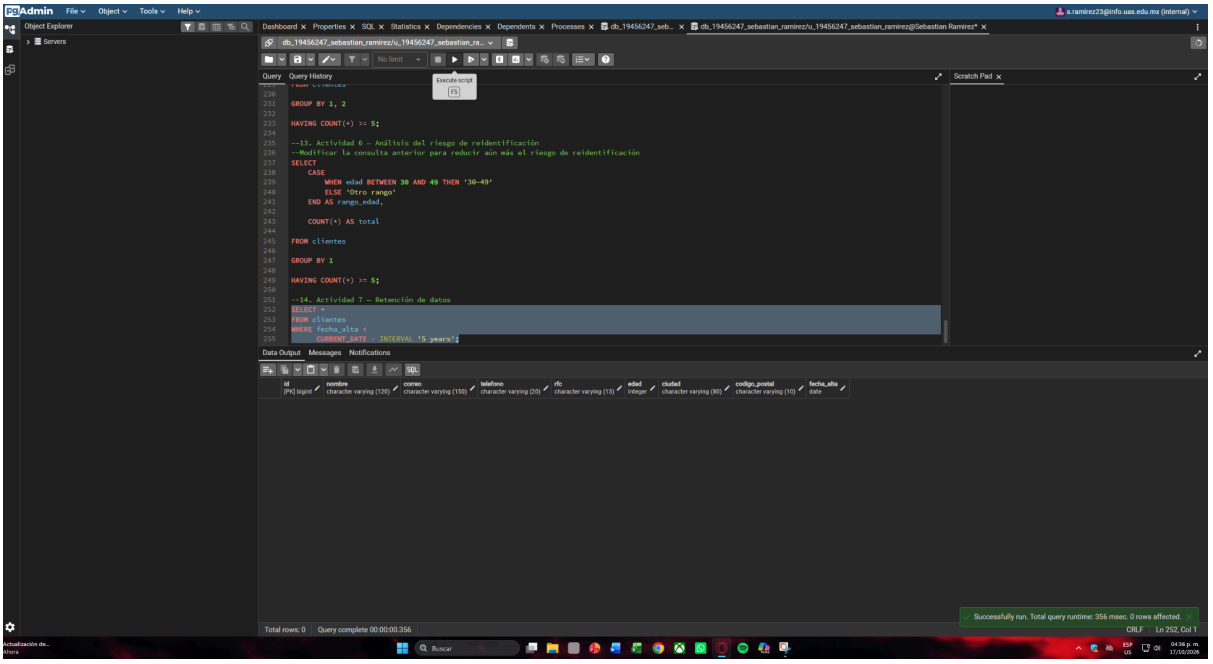
Cambio realizado: Se modificó la consulta para utilizar un rango de edad más amplio, de 30 a 49 años, y se eliminó la región de los resultados.

Motivo: Se buscó reducir la cantidad de información que podría ayudar a identificar a una persona, evitando mostrar grupos demasiado específicos.

Resultado obtenido: Los cinco clientes quedaron agrupados en un mismo rango de edad, sin mostrar sus datos personales ni su ubicación.

Riesgo que se pretende reducir: Se busca disminuir la posibilidad de identificar a un cliente mediante la combinación de su edad y su región. Sin embargo, esto no garantiza una anonimización completa.

Actividad 7 — Retención de datos



1. ¿Qué registros serían afectados?

Al ejecutar la consulta, no se encontraron registros que superaran los cinco años de antigüedad, ya que los clientes fueron registrados recientemente. Por lo tanto, ningún registro sería candidato a eliminación por este criterio en este momento.

2. ¿Cuál sería la justificación del periodo de cinco años?

Se utilizó un periodo de cinco años como ejemplo para establecer un límite de conservación de los datos. Esto permite evitar que la empresa guarde información personal durante más tiempo del necesario. En una situación real, este periodo tendría que justificarse según las necesidades de la empresa y las obligaciones legales correspondientes.

3. ¿Qué aprobación debería existir antes de eliminar información?

Antes de eliminar los datos, debería existir una autorización del responsable de la información o del área administrativa correspondiente. También se tendría que comprobar que los registros ya no sean necesarios y que su eliminación no incumpla ninguna obligación legal.

4. ¿Qué respaldo debería existir?

Se debería contar con un respaldo reciente y verificado de la base de datos, almacenado de forma segura. Esto permitiría recuperar la información si ocurriera algún problema durante el proceso de eliminación.

5. ¿Qué evidencia debería conservarse?

Se deberían guardar registros de los datos identificados para eliminación, la fecha del procedimiento, la persona responsable, la autorización correspondiente y los resultados obtenidos. Esto serviría para demostrar que el procedimiento se realizó de manera controlada.

6. ¿Qué procedimiento permitiría recuperar información eliminada accidentalmente?

Se podría utilizar un respaldo de la base de datos para restaurar la información eliminada por accidente. Antes de realizar la recuperación, sería importante identificar qué registros se perdieron y comprobar que el respaldo sea válido.